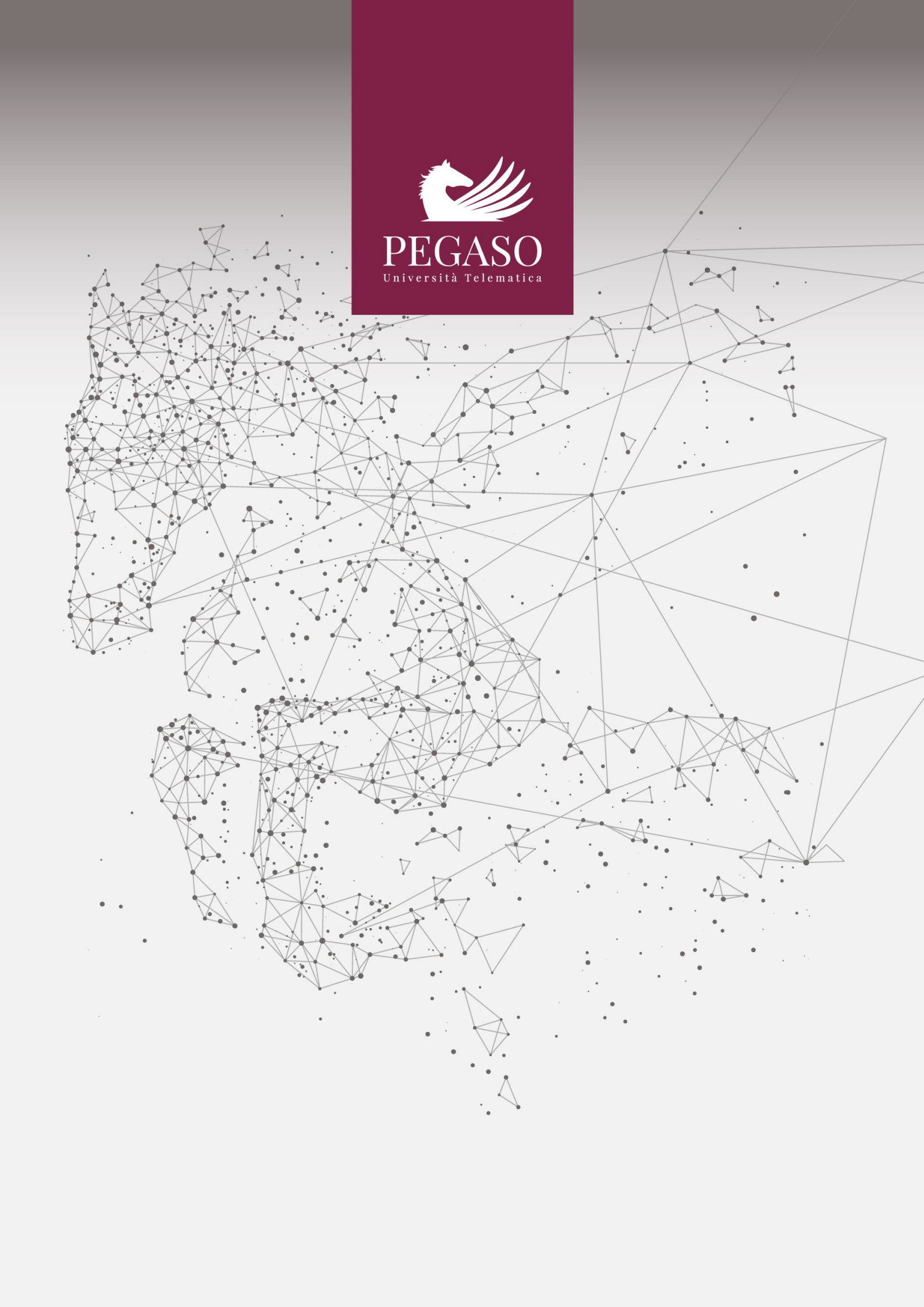

PEGASO
Università Telematica

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Indice

1. I CODICI MAC 3
2. LE FUNZIONI HASH 6
3. ATTACCO A COMPLEANNO 8
BIBLIOGRAFIA 11

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

1. I codici MAC

Un **codice MAC (Message Authentication Code)**, anche detto *checksum*, non è altro che un codice generato da una funzione C della forma:

$MAC = C(K, M)$

dove M è il messaggio che può essere di lunghezza variabile, K è una chiave segreta condivisa fra mittente e destinatario, e $C(K,M)$ è appunto il codice autenticatore di lunghezza fissa. Per realizzare la funzionalità di autenticazione tramite il codice MAC questo viene aggiunto dal mittente al messaggio da inviare; dall'altro lato il destinatario verifica l'autenticità del messaggio ricalcolando il codice MAC e comparandolo con quello ricevuto.

La funzione per il codice MAC ha la caratteristica di essere una funzione molti-a-uno e ovviamente può essere anch'essa attaccata da **un attacco a forza bruta**. Infatti, supponiamo che sia $k>n$ (con k lunghezza della chiave e n lunghezza del codice MAC), un attaccante che conosce il messaggio in chiaro M_1 e il corrispondente codice MAC_1 può provare tutte le 2^k chiavi possibili tali che $MAC_i = C(K_i,M_1)$ finché non ottiene il codice corretto MAC_1.

Esistendo però solo $2^n<2^k$ codici MAC differenti, è inevitabile che più chiavi diverse produrranno il codice corretto MAC_1; l'attaccante quindi non sa quale tra queste chiavi sia quella giusta. In media, si hanno $2^k/2^n=2^{(k-n)}$ chiavi valide, quindi l'attaccante deve ripetere l'attacco su questo sottogruppo di chiavi usando un'altra coppia [messaggio/codice MAC]. La corrispondenza, in questo secondo caso, si avrà in media per $2^{(k-n)}/2^n = 2^{(k-2n)}$ e così via per β fasi (con $\beta=k/n$) fino a quando non rimane una sola chiave.

Oltre all'attacco a forza bruta, è possibile attaccare i codici MAC anche in altri modi, vediamo un altro esempio.

Supponiamo che il messaggio sia la concatenazione di più blocchi di 64 bit X_i tale che $M=(X_1 || X_2 || .... || X_M)$ e che si abbia:

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

$\Delta(M)= X_1 \oplus X_2 \oplus .... \oplus X_M$ ovvero sia costituito dall'operazione di XOR blocco a blocco e che sia

$C(K,M)=E(K, \Delta(M))$

ovvero la creazione del codice MAC (lungo 64 bit) è fatta tramite l'algoritmo di crittografia *E(.)* che supponiamo sia il DES (con chiave K lunga 56 bit). Se un attaccante intercetta la coppia messaggio/codice MAC [M || C(K,M)] dovrebbe tentare in un attacco a forza bruta 2^{56} chiavi prima di risalire alla chiave segreta K. Tuttavia l'attaccante potrebbe non preoccuparsi di individuare K e fare un attacco più intelligente tentando di inviare messaggi fraudolenti. Infatti può sostituire i blocchi da X_1 a X_{M-1} del messaggio originale con altri blocchi desiderati ("malevoli") da Y_1 a Y_{M-1} mentre sostituisce al valore X_M il valore Y_M così calcolato:

$Y_M = Y_1 \oplus Y_2 \oplus .... \oplus Y_{M-1} \oplus \Delta(M)$

La concatenazione [M' || C(K,M)] costituita da M'= (Y_1|| Y_2 ||....|| Y_M) e dal codice MAC originario rappresenta una coppia che sarà accettata come valida dal destinatario. Ciò accade perché $\Delta(M)=\Delta(M')$ poiché lo XOR dei primi M-1 elementi (da Y_1 a Y_{M-1} in XOR con la prima parte di Y_M) dà 0.

L'attaccante riesce così ad inviare un messaggio fraudolento ma accettato come autentico di lunghezza *64(M-1)* bit.

Requisiti dei codici MAC:

Vediamo adesso quali sono i principali requisiti dei codici MAC:

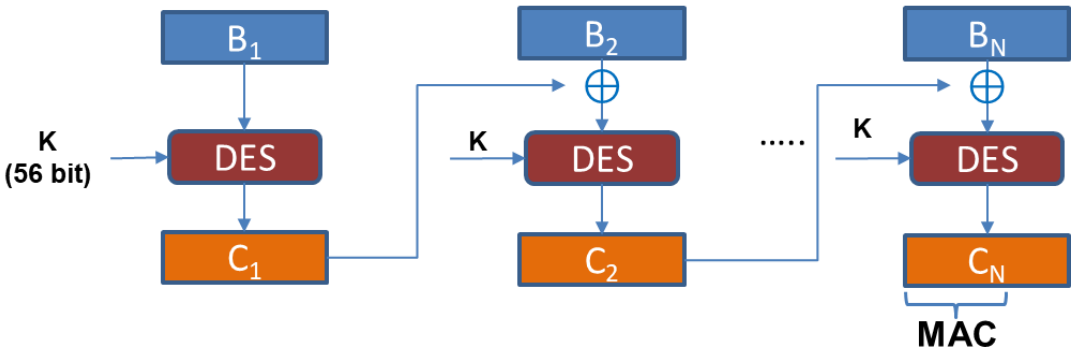
1. Noto M e C(K, M) è computazionalmente impossibile costruire M' tale che C(K,M')=C(K,M)
2. C(K, M) è uniformemente distribuito, ovvero dati M e M' la probabilità che C(K,M)=C(K,M') deve essere $1/2^n$, dove *n* è il numero di bit che compongono il codice MAC. [*Robustezza all'Attacco a forza bruta*].
3. Se M'=f(M) (per esempio f(.) inverte uno o più bit), allora, anche in questo caso, la probabilità che C(K, M)=C(K,M') deve essere $1/2^n$. [*Implica che non ci siano punti più deboli nell'algoritmo.*]

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Vediamo infine un esempio di codice MAC basato su **DES e CBC (Cipher Block Chaining)**:

Il messaggio è suddiviso in blocchi di 64 bit (se serve, l'ultimo blocco viene riempito di cifre 0). Si usa quindi il DES con chiave a 56 bit e si genera un codice cifrato di 64 bit che poi viene messo in XOR con il blocco successivo. L'output cifrato DES dell'ultimo blocco costituisce la base da cui estrarre il codice MAC che può essere formato dai primi M bit con 16≤M≤64.



Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

2. Le funzioni hash

Un valore **hash** non è altro che un codice che viene generato da una funzione H(.) applicata ad un messaggio M di lunghezza variabile con H(M) di lunghezza fissa.

Tale hash viene allegato al messaggio M ed inviato al destinatario che autentica il messaggio ricalcolando il valore di hash e confrontandolo con quello ricevuto (la funzione H(.) è pubblica). Uno dei principali requisiti è che la funzione H(M) deve essere facile da calcolare. Un altro importante requisito richiede che dato un valore fissato *h*, deve essere computazionalmente impossibile trovare x tale che *H(x)=h* (monodirezionalità).

Esistono altri due caratteristiche che devono essere presentate dalle funzioni hash e sono le seguenti:

- Proprietà della *resistenza debole alle collisioni*: dato x è computazionalmente impossibile trovare *y≠x* tale che *H(x)=H(y)*
- Proprietà della *resistenza forte alle collisioni*: è computazionalmente impossibile trovare una coppia *(x,y)* tale che *H(x)=H(y)*

Vediamo adesso come si può costruire una **semplice funzione hash basata sull'operazione di XOR**.

La funzione hash elabora i bit di input, supponiamo che *n* bit sia la lunghezza di ognuno degli *m* blocchi. Il codice hash è costituito da *n* bit ognuno dei quali è creato dall'operazione di XOR fra tutti i bit in quella posizione (tutti i primi bit, tutti i secondi bit, ecc.). In figura è riportata una esemplificazione.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

$C_{11}=b_{11}\oplus b_{12}\oplus .....b_{1m}$ $\quad$ $0=1\oplus 1\oplus 0$

$C_{21}=b_{21}\oplus b_{22}\oplus .....b_{2m}$ $\quad$ $1=0\oplus 1\oplus 0$

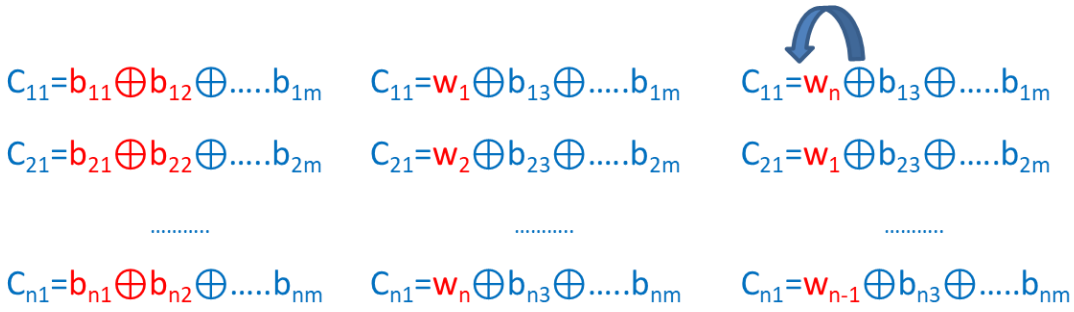
..... $\quad$ .....

$C_{n1}=b_{n1}\oplus b_{n2}\oplus .....b_{nm}$ $\quad$ $1=1\oplus 0\oplus 0$

Non è così efficace però, se ci sono delle parti del messaggio con stessi valori (per esempio tutti 0) il risultato è sempre lo stesso e ciò può essere usata dall'analisi crittografica.

Un altro esempio di semplice funzione hash è quella **basata su RXOR (Ruotato)**

Per evitare la problematica presentata dalla funzione hash precedente, si può procedere ruotando il codice hash prima di eseguire la successiva operazione di XOR al fine di casualizzare l'input (vedi figura sottostante).



Tuttavia, anche in questo caso, non si è sicuri. Se si utilizza questa procedura, nel caso di invio di messaggio in chiaro e di corrispettivo hash, un attaccante può generare un nuovo messaggio fraudolento aggiungervi un ultimo blocco di *n* bit tale da ottenere, tramite l'operazione di XOR, l'hash originario. A questo punto il nuovo messaggio alterato sarà accettato come autentico in quanto verifica l'hash.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

3. Attacco a compleanno

Vediamo adesso cosa si intende quando si parla di **attacco a compleanno** e perché è molto importante nell'analisi della sicurezza in crittografia.

Supponiamo di usare un hash H(M) da 64 bit e che tale hash sia inviato insieme al messaggio M non cifrato. Un attaccante potrebbe trovare un nuovo messaggio M' tale che H(M') = H(M) attraverso un attacco a forza bruta che però richiederebbe in media 2^{63} tentativi. In realtà esiste la possibilità di effettuare un altro tipo di attacco basato sul paradosso del compleanno, detto appunto **attacco a compleanno**, vediamone le varie fasi.

1. Il mittente A si prepara a firmare un messaggio aggiungendo il corrispondente codice hash di *m* bit cifrato con la propria chiave privata
2. L'attaccante genera $2^{m/2}$ (2^{32} se m=64) varianti del messaggio M ovvero messaggi che hanno sostanzialmente lo stesso significato come l'esempio riportato qui di seguito:

{Avrei piacere di/Potrei} incontrarti {a/per} cena alle {8.00pm/20.00} tale esempio contiene 2^3 varianti.

3. Analogamente l'attaccante prepara $2^{m/2}$ varianti del messaggio F fraudolento da sostituire al vero messaggio
4. I due insiemi di messaggi vengono confrontati per trovare una coppia di messaggi (M', F') che danno lo stesso hash: H(M') = H(F')
5. Per il paradosso del compleanno la probabilità di successo è superiore a ½; nel caso in cui non venga trovata nessuna corrispondenza vengono generati altri messaggi validi e fraudolenti e si riprova.
6. A questo punto, l'attaccante offre all'utente A l'hash H(M') [che vale quanto H(F')] per la firma e associa tale firma alla variante fraudolenta del messaggio F' ed entrambe vengono inviate al destinatario.
7. Il destinatario ricalcola l'hash su F' e verificato che è uguale a quello firmato inviatogli dall'utente A, accetta il messaggio F' come autentico e proveniente dall'utente A.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

8. La complessità per l'attaccante sta nel generare 2^{32} varianti del messaggio, basta costruire, per esempio, 32 coppie di parole varianti (vedi esempio precedente 2^3 varianti).

Vediamo adesso nel dettaglio l'attacco a compleanno e cerchiamo di capire come mai la probabilità che si verifichi sia la stessa di tirare una moneta.

Formulazione

Dato un hash H che produce *n* possibili output e il valore H(x), se H(.) viene applicato a *k* input casuali, quale deve essere il valore di k tale che la probabilità che almeno un input *y* soddisfi H(y)=H(x) sia ½?

- Per un determinato valore di *y* la probabilità che H(y)=H(x) è pari a 1/n, quindi Pr{H(y)≠H(x)}=[1-1/n].
- Se si fanno k tentativi allora $Pr\{H(y)\neq H(x)\}=[1-1/n]^k$, conseguentemente la $Pr\{H(y)=H(x)\}=1-[1-1/n]^k$
- Il termine $(1-a)^k$ per valori piccoli di *a* può essere approssimato a *(1-ka)*, quindi Pr{H(y)=H(x)} ≈ 1-1+k/n = k/n
- Per avere che tale probabilità sia uguale a ½ allora bisogna avere *k=n/2*. Ovvero $k=(2^m)/2$ nel caso di un hash composto da *m* bit.

Per capire ancora meglio, vediamo anche il cosiddetto **paradosso del compleanno** che sta alla base dell'omonimo attacco.

La domanda è la seguente: quale deve essere il numero minimo di persone (indicato con *k*) tale che la probabilità che almeno due persone abbiano lo stesso compleanno sia maggiore di ½? Facciamo delle assunzioni: escludiamo il 29 febbraio, consideriamo i compleanni equiprobabili e k<365 altrimenti c'è già almeno una coincidenza.

- Si deve trovare il valore più piccolo di *k* tale che l'evento P(365, *k*) ≥ ½ sia verificato.
- Calcoliamo il complemento Q(365, *k*) (non accade che ci sia coincidenza di compleanni); indicando con N il numero delle possibili combinazioni si ha che:

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

N=365x364x363x…..(365-k+1)= 365! / (365-k)!

- Se si assume che non ci siano duplicazioni il numero totale di possibilità è 365^k e quindi si ha che:

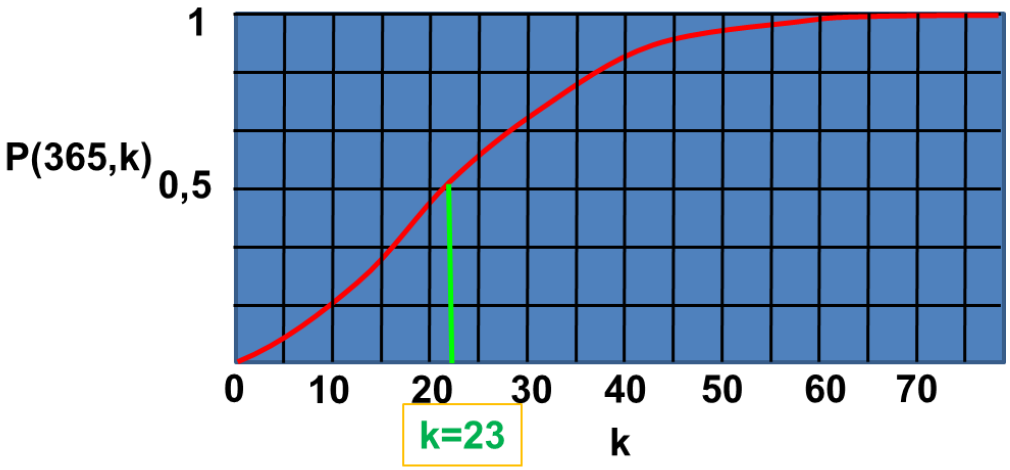
  Q(365, k)= [365! / (365−k)!] / 365^k

  per cui

$$P(365, k) = 1- Q(365, k) = 1- \{[365! / (365-k)!] / 365^k\}$$

Se si va a disegnare l'andamento di P(365, k) (vedi figura sottostante in cui è rappresentato un andamento indicativo) si riesce a vedere che P(365,k=23) = 0,5073, addirittura la P(365,100)=0,9999997.

Significa, in pratica, che all'interno di una classe scolastica (per esempio k=23) c'è una probabilità di ½ che due alunni siano nati lo stesso giorno dell'anno.



PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Bibliografia

- Libro di riferimento "Crittografia e Sicurezza delle Reti" 2 ed., William Stallings, Ed. McGraw-Hill: Capitoli 11.
- "Cryptography and Network Security", 7/ed, William Stallings, Pearson.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).